Lesson 4

Identifying Social Engineering and Malware

CompTIA®

Social Engineering

- “Hacking the human”
- Purposes of social engineering
  - Reconnaissance and eliciting information
  - Intrusion and gaining unauthorized access
- Many possible scenarios
  - Persuade a user to run a malicious file
  - Contact a help desk and solicit information
  - Gain access to premises and install a monitoring device

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Social Engineering Principles

- Reasons for effectiveness
- Familiarity/liking
  - Establish trust
  - Make request seem reasonable and natural
- Consensus/social proof
  - Exploit polite behaviors
  - Establish spoofed testimonials or contacts
- Authority and intimidation
  - Make the target afraid to refuse
  - Exploit lack of knowledge or awareness
- Scarcity and urgency
  - Rush the target into a decision

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Impersonation and Trust

- Impersonation
  - Pretend to be someone else
  - Use the persona to charm or to intimidate
  - Exploit situations where identity-proofing is difficult
- Pretexting
  - Using a scenario with convincing additional detail
- Trust
  - Obtain or spoof data that supports the identity claim

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Dumpster Diving and Tailgating

- Dumpster diving
  - Steal documents and media from trash
- Tailgating
  - Access premises covertly
  - Follow someone else through a door
- Piggy backing
  - Access premises without authorization, but with the knowledge of an employee
  - Get someone to hold a door open

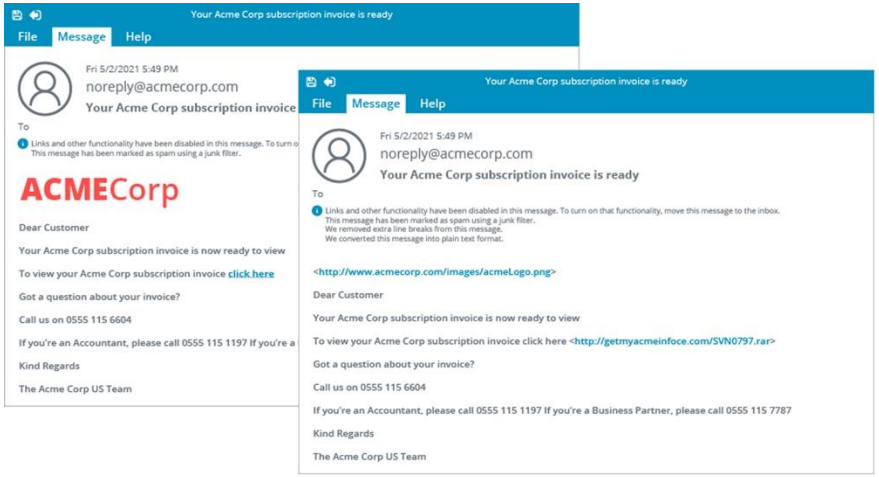
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Identity Fraud and Invoice Scams

- Identity fraud
  - Impersonation with convincing detail and stolen or spoofed proofs
  - Identity fraud versus identity theft
- Invoice scams
  - Spoofing supplier details to submit invoices with false account details
- Credential theft and misuse
  - Credential harvesting
  - Shoulder surfing
  - Lunchtime attack

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Phishing, Whaling, and Vishing



- Trick target into using a malicious resource
- Spoof legitimate communications and sites
- Spear phishing
  - Highly targeted/tailored attack
- Whaling
  - Targeting senior management
- Vishing
  - Using a voice channel
- SMiShing
  - Using text messaging

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Spam, Hoaxes and Prepending

- Spam
  - Unsolicited email
  - Email address harvesting
  - Spam over Internet messaging (SPIM)
- Hoaxes
  - Delivered as spam or malvertising
  - Fake A-V to get user to install remote desktop software
  - Phone-based scams
- Prepending
  - Tagging email subject line
  - Can be used by threat actor as a consensus or urgency technique
  - Can be added by mail systems to warn users

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Pharming and Credential Harvesting

- Passive techniques have less risk of detection
- Pharming
  - Redirection by DNS spoofing
- Typosquatting
  - Use cousin domains instead of redirection
  - Make phishing messages more convincing
- Watering hole
  - Target a third-party site
  - Customer, supplier, hobbies, social media…
- Credential harvesting
  - Attacks focused on obtaining credentials for sale rather than direct intrusion
  - Attacks focused on obtaining multiple credentials for single company

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Influence Campaigns

- Sophisticated threat actors using multiple resources to change opinions on a mass scale
- Soft power
  - Leveraging diplomatic and cultural assets
- Hybrid warfare
  - Use of espionage, disinformation, and hacking
- Social media
  - Use of hacked accounts and bot accounts
  - Spread rumor and reinforce messaging

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 4B

Analyze Indicators of Malware-based Attacks

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

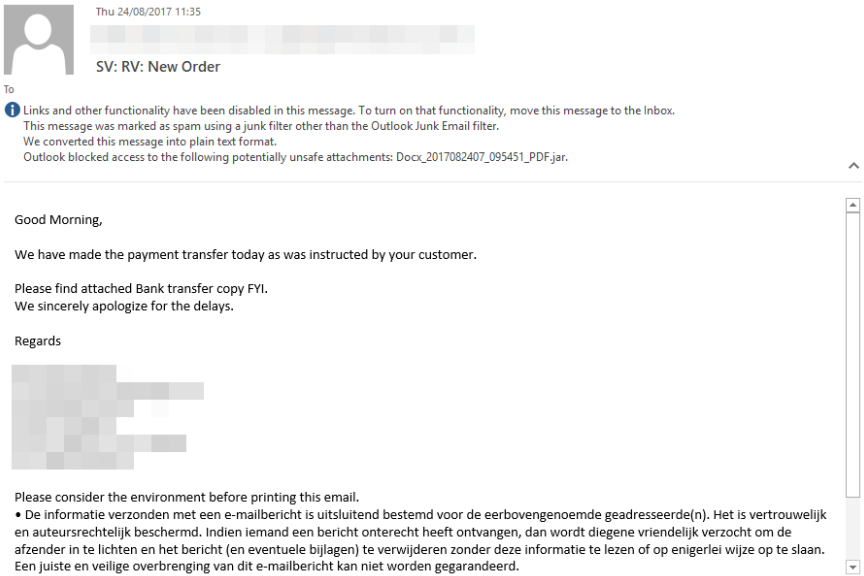
Malware Classification

- Classification by vector or infection method
- Viruses and worms
  - Spread within code without authorization
- Trojans
  - A malicious program concealed within a benign one
- Potentially unwanted programs/applications (PUPs/PAPs)
  - Pre-installed “bloatware” or installed alongside another app
  - Not completely concealed, but installation may be covert
  - Also called grayware
- Classification by payload

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Computer Viruses

- Rely on some sort of host file or media
  - Non-resident/file infector
  - Memory resident
  - Boot
  - Script/macro
- Multipartite
- Polymorphic
- Vector for delivery



Screenshot used with permission from Microsoft.

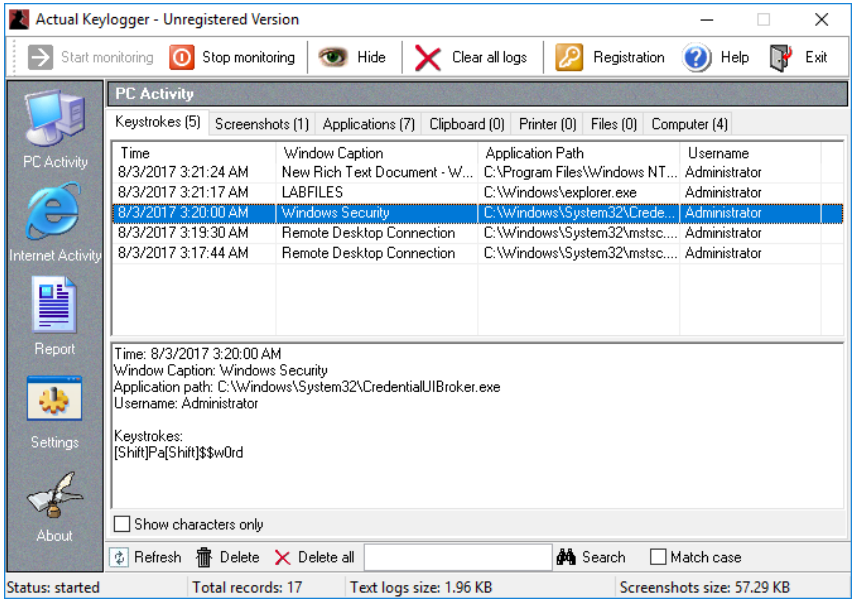
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Computer Worms and Fileless Malware

- Early computer worms
  - Propagate in memory/over network links
  - Consume bandwidth and crash process
- Fileless malware
  - Exploiting remote execution and memory residence to deliver payloads
  - May run from an initial script or Trojan
  - Persistence via the registry
  - Use of shellcode to create backdoors and download additional tools
  - “Living off the land” exploitation of built-in scripting tools
- Advanced persistent threat (APT)/advanced volatile threat (AVT)/ low observable characteristics (LOC)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Spyware, Adware, and Keyloggers



Screenshot used with permission from ActualKeylogger.com.

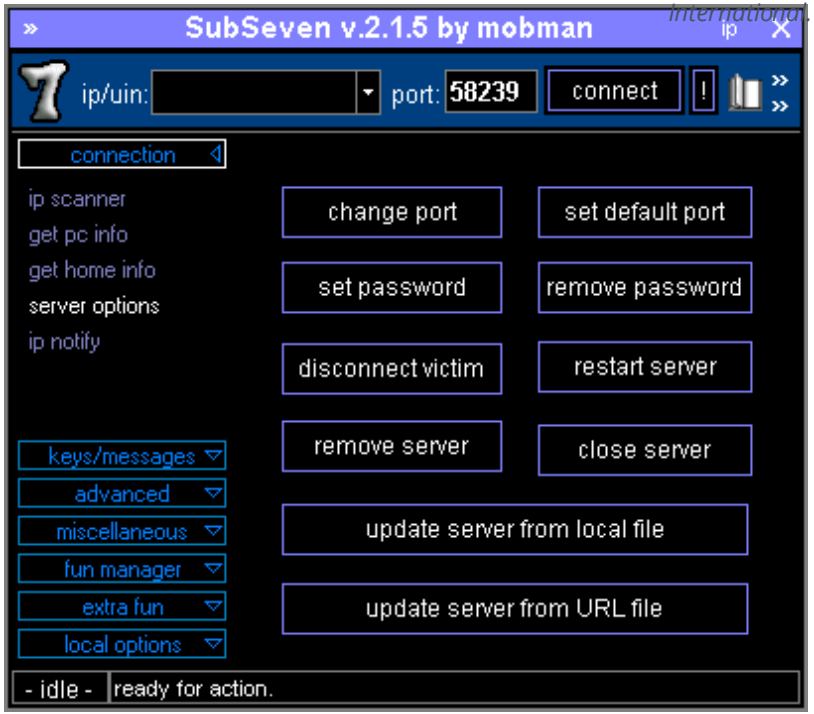
- Tracking cookies
- Adware (PUP/grayware)
  - Changes to browser settings
- Spyware (malware)
  - Log all local activity
  - Use of recording devices and screenshots
  - Redirection
- Keylogger
  - Software and hardware

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Backdoors and Remote Access Trojans

- Backdoor malware
- Remote access trojan (RAT)
- Bots and botnets
- Command & control (C2 or C&C)
- Backdoors from misconfiguration and unauthorized software

Screenshot used with permission from Wikimedia Commons by CCAS4.0 International.



Rootkits

- Local administrator versus SYSTEM/root privileges
- Replace key system files and utilities
- Purge log files
- Firmware rootkits

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Ransomware, Crypto-Malware, and Logic Bombs

- Ransomware
  - Nuisance (lock out user by replacing shell)
- Crypto-malware
  - High impact ransomware (encrypt data files or drives)
- Cryptomining/crypojacking
  - Hijack resources to mine cryptocurrency
- Logic bombs

Image by Wikimedia Commons.

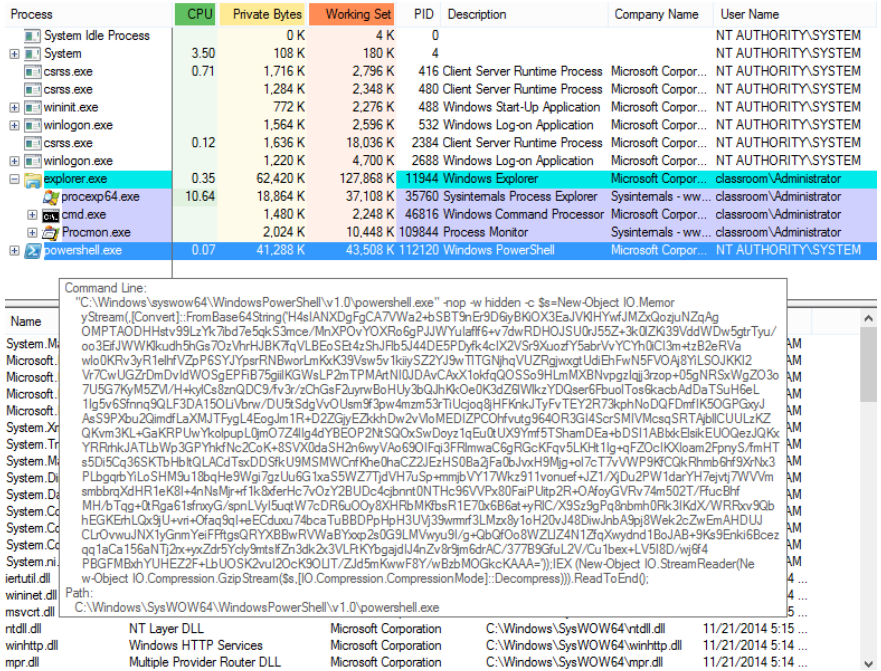
Malware Indicators

- Browser changes or overt ransomware notification
- Anti-virus notifications
  - Endpoint protection platforms and next-gen A-V
  - Behavior-based analysis
- Sandbox execution
  - Cuckoo
- Resource utilization/consumption
  - Task Manager and top
- File system changes
  - Registry
  - Temp files

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Process Analysis

Screenshot: Process Explorer docs.microsoft.com/en-us/sysinternals.



- Signature-based detection is failing to identify modern APT-style tools
- Network and host behavior anomalies drive detection methods
- Running process analysis
  - Process Explorer
- Logging activity
  - System Monitor
- Network activity

Lesson 5

Summarizing Basic Cryptographic Concepts

CompTIA®

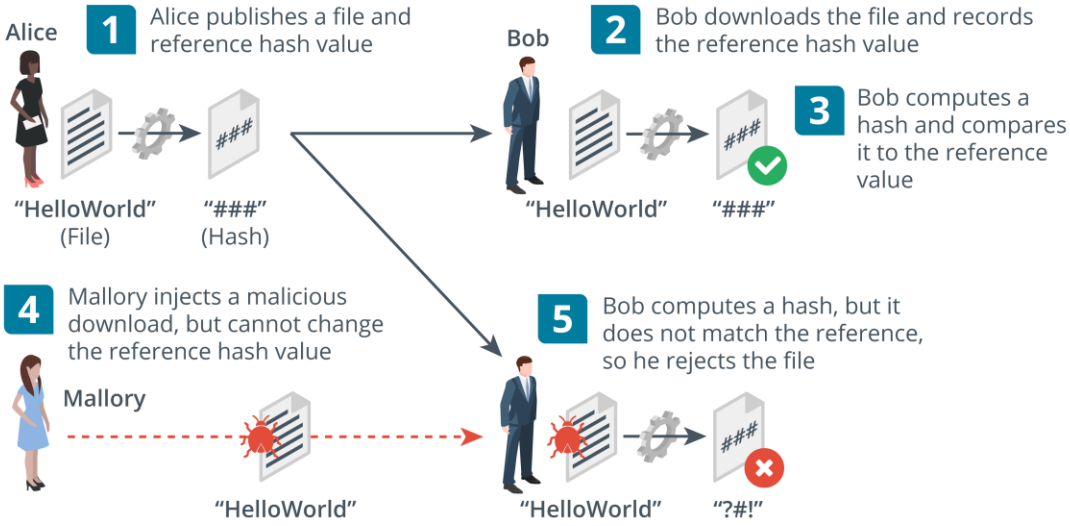
Cryptographic Concepts

- Encryption and decryption—encoding and decoding
  - Plaintext is the unencoded message
  - Ciphertext is the coded message
  - Cipher is the means of change or algorithm
  - Cryptanalysis is the art of cracking cryptographic systems
- Meet Alice and Bob (and observe Mallory, lurking)
- Hashing algorithms
- Encryption ciphers
  - Symmetric
  - Asymmetric

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Hashing Algorithms

- Fixed length hash from variable string with cryptographic properties
  - One-way (plaintext cannot be recovered from the digest)
  - Anti-collision (no two plaintexts are likely to produce the same checksum)
- Used for password storage and checksums (integrity)
- Secure Hash Algorithm (SHA)
- Message Digest Algorithm (MD5)



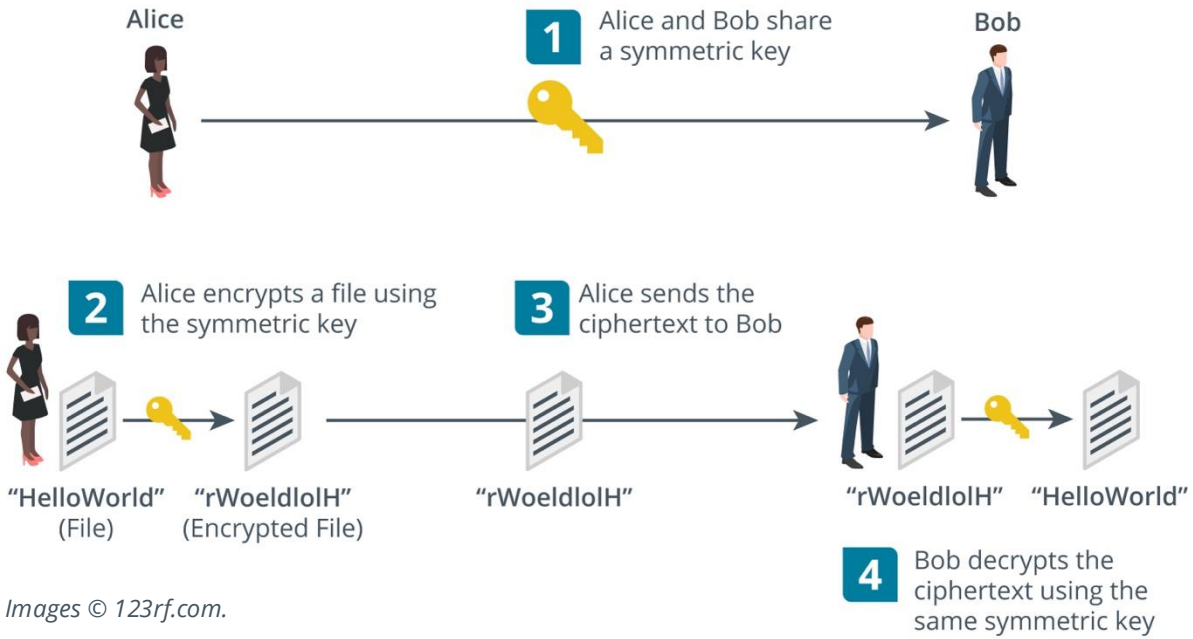
Images © 123rf.com.

Encryption Ciphers and Keys

- Hashing is not encryption—the process is not reversible
- Encryption uses a reversible process based on a secret
- Process should be too complex to unravel without the secret
  - Substitution
  - Transposition
- Cannot keep the cipher/algorithm itself secret
- Key ensures ciphertext remains protected even when the operation of the cipher is known
- Protecting the key is easier than protecting the algorithm

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Symmetric Encryption



Images © 123rf.com.

- Same secret key is used for encryption and decryption
- Fast—suitable for bulk encryption of large amounts of data
- Problem storing and distributing key securely
- Confidentiality only—sender and recipient know the same key

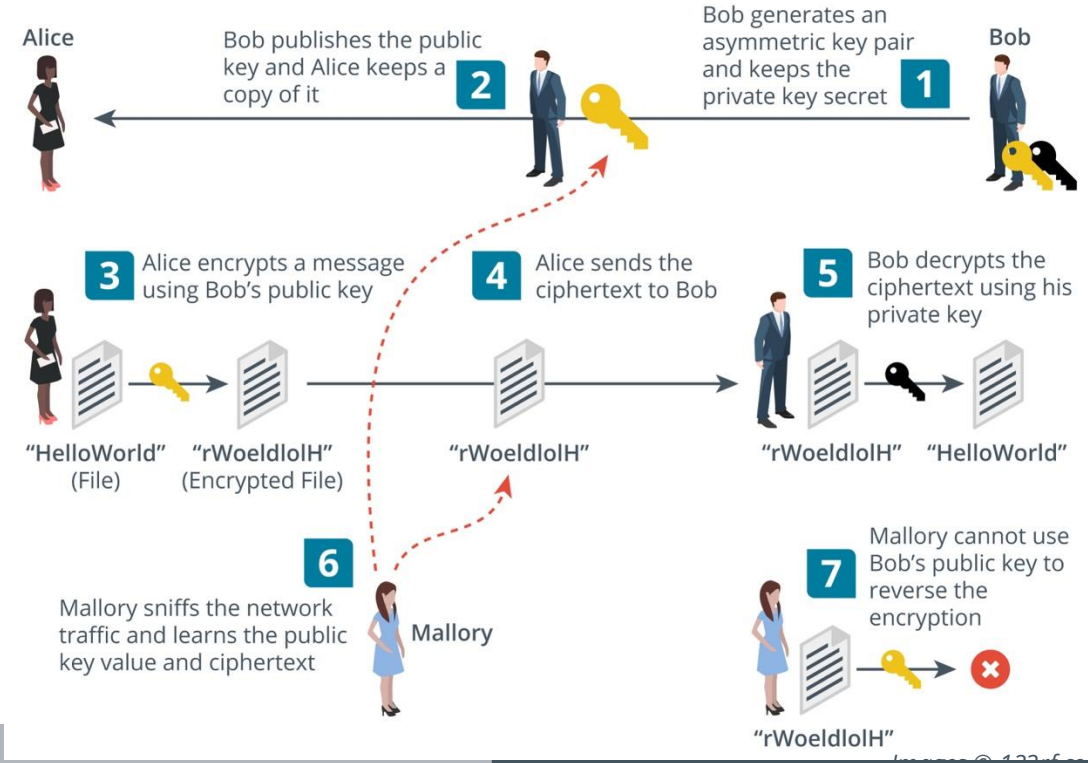
Stream and Block Ciphers

- Stream ciphers
  - Encrypt and decrypt each bit/byte at a time
  - Must be used with an initialization vector (IV)
- Block ciphers
  - Treat data as equal-size blocks, using padding if necessary
  - Advanced Encryption Standard (AES/AES256)
- Key length
  - Range of key values is the keyspace
  - Longer key bit length means a larger keyspace
  - Strength of key of any given length varies between ciphers

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Asymmetric Encryption

- Public/private key pair
  - If the public key encrypts, only the private key can decrypt
  - If the private key encrypts, only the public key can decrypt
  - Private key cannot be derived from the public key
  - Private key must be kept secret
  - Public key is easy to distribute (anyone can have it)
- Message size is limited to key size so not suitable for large amounts of data
- Used for small amounts of authentication data



Public Key Cryptography Algorithms

- RSA algorithm (Rivest, Shamir, Adleman)
  - Basis of many public key cryptography schemes
  - Trapdoor function
  - Easy to calculate with the public key, but difficult to reverse without the private key
- Elliptic curve cryptography (ECC)
  - Concerns about RSA being vulnerable to cryptanalysis
  - Another type of trapdoor function
  - Can use smaller keys to obtain same security

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

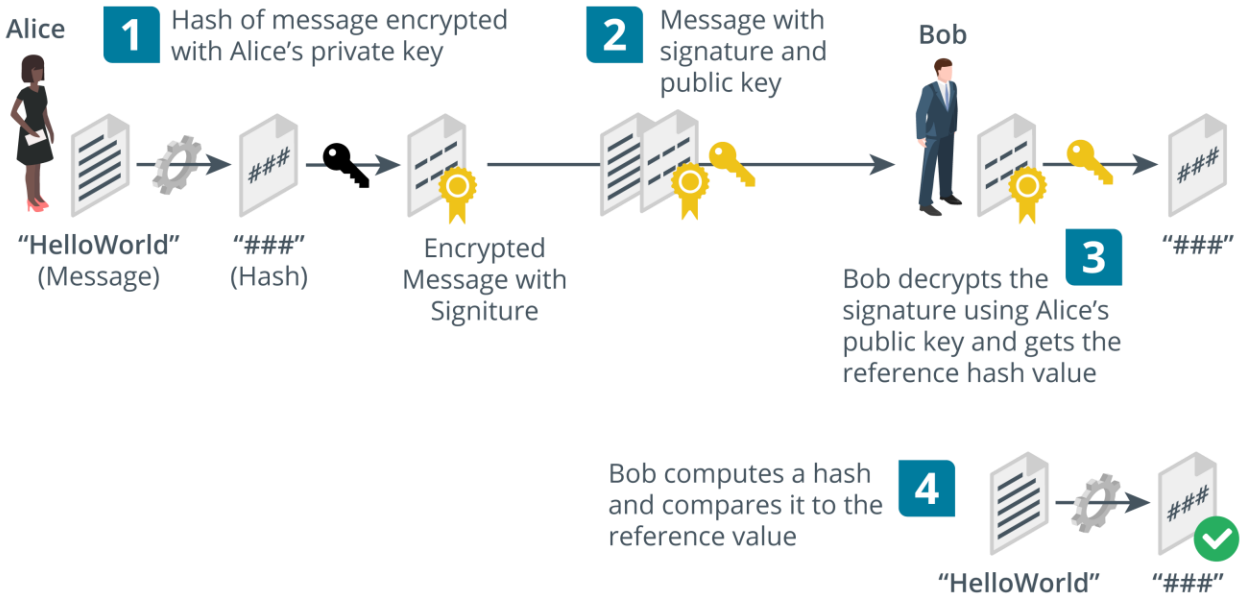
Topic 5B

Summarize Cryptographic Modes of Operation

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

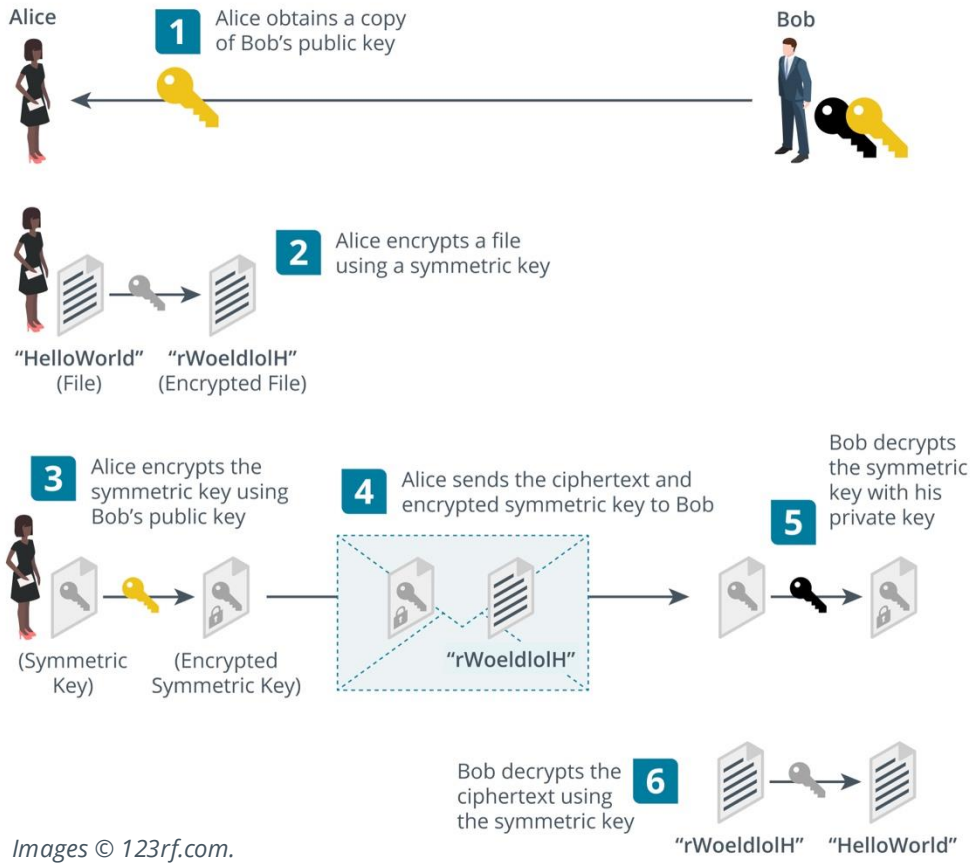
Digital Signatures

- Using public key cryptography with hashing
- Digital signatures provide integrity, authentication, non-repudiation
- RSA-based digital signatures
- Digital Signature Algorithm (DSA) with ECC cipher



Images © 123rf.com.

Digital Envelopes and Key Exchange



Images © 123rf.com.

Digital Certificates

- Wrapper for a public key to associate it with a digital identity
- Identity assertion is validated by a certificate authority (CA) by signing the certificate
- Both parties must trust the CA
- Referred to as public key infrastructure (PKI)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Perfect Forward Secrecy

- RSA key exchange decrypts the session key using the server private key
- The private key stored on the server may be compromised in the future
- If key is compromised, previously captured transmissions could be deciphered
- Perfect forward secrecy (PFS) mitigates this issue
- Uses Diffie-Hellman key agreement protocols
- Allows two parties to derive the same secret value that an eavesdropper cannot guess

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cipher Suites and Modes of Operation

- Cipher suite
  - Signature algorithm—proves messages were created by the server (authentication and integrity)
  - Key exchange/agreement algorithm—allows client and server to agree session keys
  - Bulk encryption cipher—uses the session key to keep the data confidential
- Modes of operation
  - Use symmetric block cipher with arbitrary length network data
  - Cipher Block Chaining (CBC)
    - Combines blocks and an initialization vector (IV) using XOR operation
    - Data must be a multiple of block size so requires padding for last block
  - Counter mode
    - Generates keystream with IV and counter
    - Does not require block padding

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Authenticated Modes of Operation

- Unauthenticated encryption
  - Secret key encryption cannot prove integrity
  - Makes cryptographic system vulnerable to insertion and modification attacks
- Authenticated encryption
  - Message authentication code (MAC)
  - Create a hash from combination of the message and a shared secret
  - Implementations vulnerable to padding oracle attacks
- Authenticated encryption with additional data (AEAD)
  - Counter modes or stream ciphers that do not use padding
  - Associates message with context to prevent replay

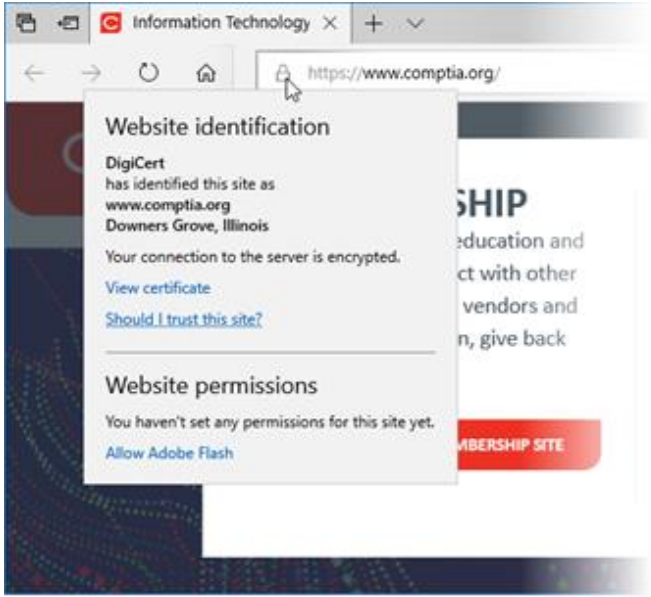
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 5C

Summarize Cryptographic Use Cases and Weaknesses

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cryptography for Authentication and Non-repudiation



Screenshot used with permission from Microsoft.

- Cryptographic primitives versus cryptographic systems
- Authentication and access control
  - Assuming the private key is secure, an encrypted token could only have been created by the key holder
- Non-repudiation
  - Sender cannot deny (repudiate) the message as only she/he could have created it

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cryptography Supporting Confidentiality

- Hybrid encryption
  - Public key cryptography is only efficient with small amounts of data
  - Symmetric encryption makes key distribution difficult
  - Symmetric key is used for bulk encryption and protected by public key cryptography
- File encryption
  - Private key encrypts the symmetric key
  - Use of the key is locked to a user account credential
- Transport encryption
  - Session key exchange/agreement

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cryptography Supporting Integrity and Resiliency

- Integrity
  - Using hash functions and message authentication codes to validate messages
- Resiliency
  - Using cryptography to ensure authentication and integrity of control messages
- Obfuscation
  - Make something hard to understand
  - Encryption can perform this function, but it is very hard to secure an embedded key
  - White box cryptography

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cryptographic Performance Limitations

- Limitations
  - Speed—Amount of data/number of operations per second
  - Time/latency—Delay in completing an operation
  - Size—Key size increases security but also CPU/memory requirements
  - Computational overhead—Complexity of cryptographic implementation or cipher
- Resource-constrained environments
  - Low-power devices
    - Battery-powered systems
    - Contactless smart cards
  - Low latency
    - Delay-sensitive communications protocols/implementations

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cryptographic Security Limitations

```
administrator@LAMP16:~$ gpg --gen-key
gpg (GnuPG) 1.4.20; Copyright (C) 2015 Free Software Foundation, Inc.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.

Please select what kind of key you want:
   (1) RSA and RSA (default)
   (2) DSA and Elgamal
   (3) DSA (sign only)
   (4) RSA (sign only)
Your selection? 1
RSA keys may be between 1024 and 4096 bits long.
What keysize do you want? (2048) 2048
Requested keysize is 2048 bits
Please specify how long the key should be valid.
         0 = key does not expire
      <n>  = key expires in n days
      <n>w = key expires in n weeks
      <n>m = key expires in n months
      <n>y = key expires in n years
Key is valid for? (0) 2y
Key expires at Fri 30 Aug 2019 06:27:41 AM PDT
Is this correct? (y/N) y

You need a user ID to identify your key; the software constructs the user ID
from the Real Name, Comment and Email Address in this form:
    "Heinrich Heine (Der Dichter) <heinrichh@duesseldorf.de>"

Real name: gtslearning
Email address: support@gtslearning
Comment:
You selected this USER-ID:
    "gtslearning <support@gtslearning>"

Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? o
You need a Passphrase to protect your secret key.

gpg: gpg-agent is not available in this session
We need to generate a lot of random bytes. It is a good idea to perform
some other action (type on the keyboard, move the mouse, utilize the
disks) during the prime generation; this gives the random number
generator a better chance to gain enough entropy.

Not enough random bytes available.  Please do some other work to give
the OS a chance to collect more entropy! (Need 237 more bytes)
```

- Entropy
  - Checksums and ciphertext must reduce order (high entropy)
  - Weak ciphers and weak keys
  - Weak implementations
  - Weak randomness
- Predictability and reuse
  - Nonce
  - Initialization vector (IV)
  - Salt

Longevity and Cryptographic Attacks

- How secure are current algorithms?
- How long must a ciphertext be resistant to attacks?

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Man-in-the-Middle and Downgrade Attacks

- Man-in-the-Middle (MitM)
  - Interferes with the public key presented to the client
- Downgrade attack
  - Forces server into using weak protocol versions and ciphers

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Key Stretching and Salting

- User-generated data is low entropy
- Key stretching
  - Use additional rounds to strengthen keys
  - Makes attacker do more work so slows down brute force
- Salting
  - Add a random value to each password when hashing it for storage
  - Prevents use of pre-computed hash tables

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Collisions and the Birthday Attack

- Exploit collisions to forge a signature
- Math of birthday paradox shows that this might be easier than expected
- Chosen prefix collision attacks

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 5D

Summarize Other Cryptographic Technologies

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Quantum

- Quantum computing
  - Quantum bit (qubits), superpositions, entanglement and collapse
  - Quantum computers can keep track of a lot of state data at the same time
- Communications
  - Tamper-evident key distribution
- Post-quantum
  - Quantum-based cryptanalysis
  - Post-quantum cryptography (replacements for the current algorithms)
- Lightweight cryptography

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Homomorphic Encryption

- Supports data analytics functions while preserving confidentiality and privacy

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Blockchain

- Expanding list of transactional records (blocks)
- Each block is linked by hashing
- Public ledger
  - Ledger of transactions performed on a digital asset
  - Peer-to-peer so transactions are public
  - Transactions cannot be deleted or reversed
- Widely used for cryptocurrencies
- Potential uses for financial transactions, online voting systems, identity management systems, notarization, data storage, …

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Steganography

- Concealing messages within a covertext
- Often uses file data that can be manipulated without introducing obvious artifacts
  - Image
  - Audio
  - Video
- Covert channels

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 6A

Implement Certificates and Certificate Authorities

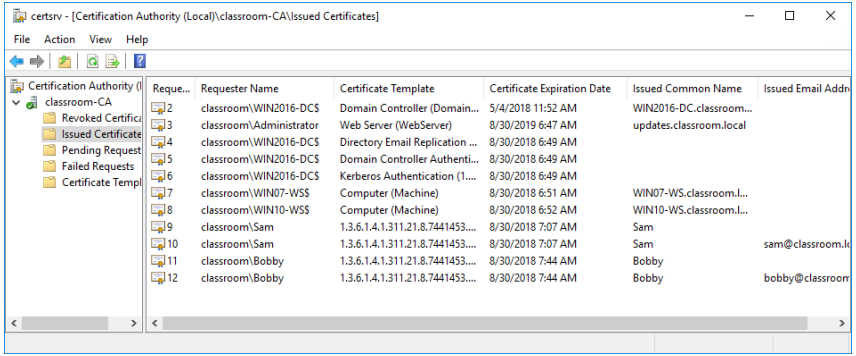
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Public and Private Key Usage

- Public key cryptography
  - When you want others to send you confidential messages, you give them your public key to use to encrypt the message
  - When you want to authenticate yourself to others, you create a signature and sign it by encrypting the signature with your private key
- But how does someone trust the public key?
- Public key infrastructure (PKI) validates the identity of the owner of a public key
- Public key is wrapped in a digital certificate signed by a certificate authority (CA)
- Sender and recipient must both trust the CA

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate Authorities

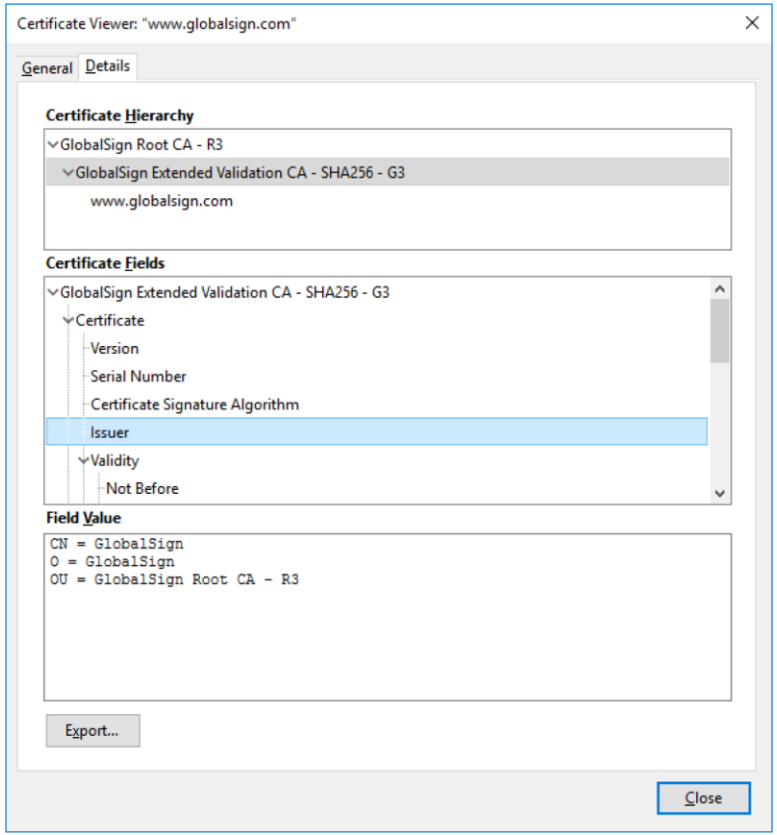


Screenshot used with permission from Microsoft.

- Private CAs versus third-party CAs
- Define services offered
- Ensure validity of certificates and users
- Establish trustworthy working procedures
- Manage servers and keys

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

PKI Trust Models and Certificate Chaining



Screenshot used with permission from Microsoft.

- Single CA
- Hierarchical/chain of trust
  - Root CA
  - Intermediate CAs
  - Leaf certificates
- Online versus offline

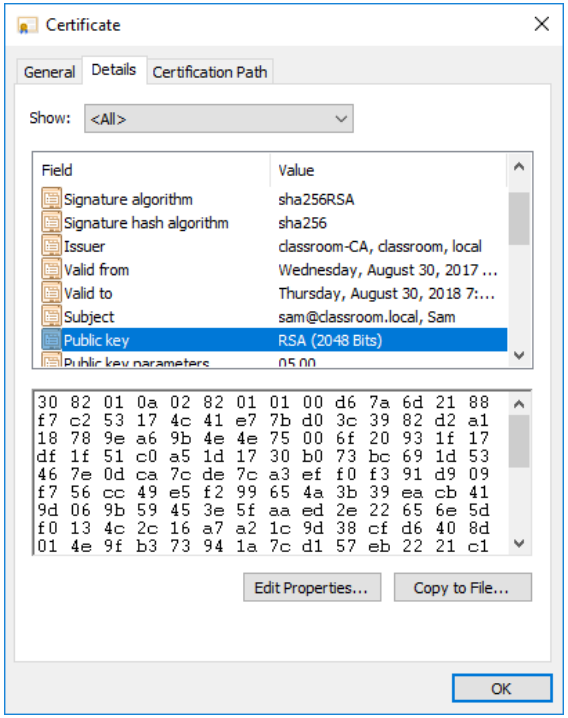
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Registration and CSRs

- Registration identification and authentication procedures
  - Private versus third-party CAs
- Certificate Signing Request (CSR)
  - Client generates key pair and sends public key to CA with CSR
  - CA performs subject identity checks
  - CA signs and issues certificate
- Registration authority (RA)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Digital Certificates



Screenshot used with permission from Microsoft.

- Contains subject's public key
- Information identifying the subject plus usage and validity
- Digital certificate standards
  - X.509 Public Key Infrastructure (PKIX)
  - PKCS (Public Key Cryptography Standards)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

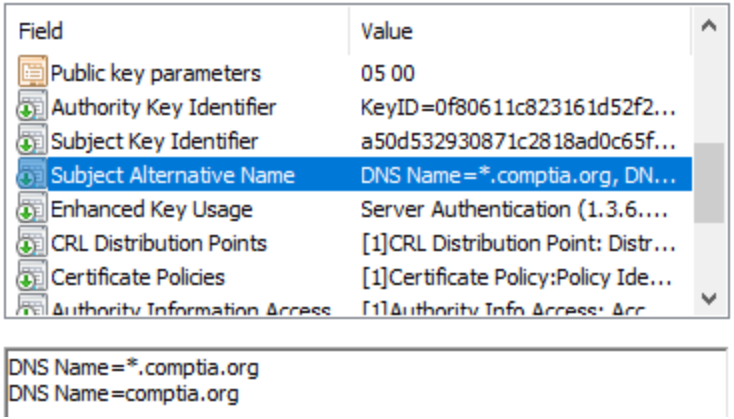
Certificate Attributes

Field	Usage
Serial Number	A number uniquely identifying the certificate within the domain of its CA.
Signature Algorithm	The algorithm used by the CA to sign the certificate.
Issuer	The name of the CA.
Valid From/To	Date and time during which the certificate is valid.
Subject	The name of the certificate holder, expressed as a distinguished name (DN). Within this, the Common Name (CN) part should usually match either the fully qualified domain name (FQDN) of the server or a user email address.
Public Key	Public key and algorithm used by the certificate holder.
Extensions	V3 certificates can be defined with extended attributes, such as friendly subject or issuer names, contact email addresses, and intended key usage.
Subject Alternative Name (SAN)	This extension field is the preferred mechanism to identify the DNS name or names by which a host is identified.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Subject Name Attributes

- Common Name (CN)
  - Legacy method of recording FQDN
  - Deprecated by standards
  - BUT still used in many implementations
- Subject Alternative Name (SAN)
  - Structured identifiers
  - List multiple host/subdomains
  - Use wildcard subdomain

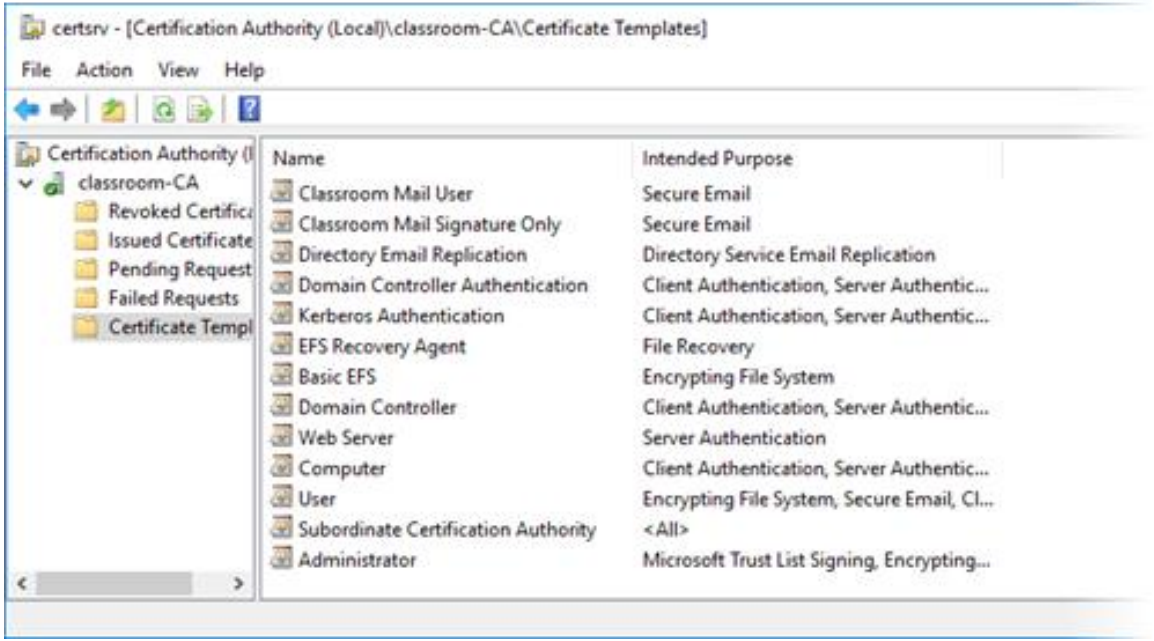


Screenshot used with permission from Microsoft.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Types of Certificate

- Certificate policies and templates
- Key usage
- Extended Key Usage/Enhanced Key Usage
- Critical or non-critical

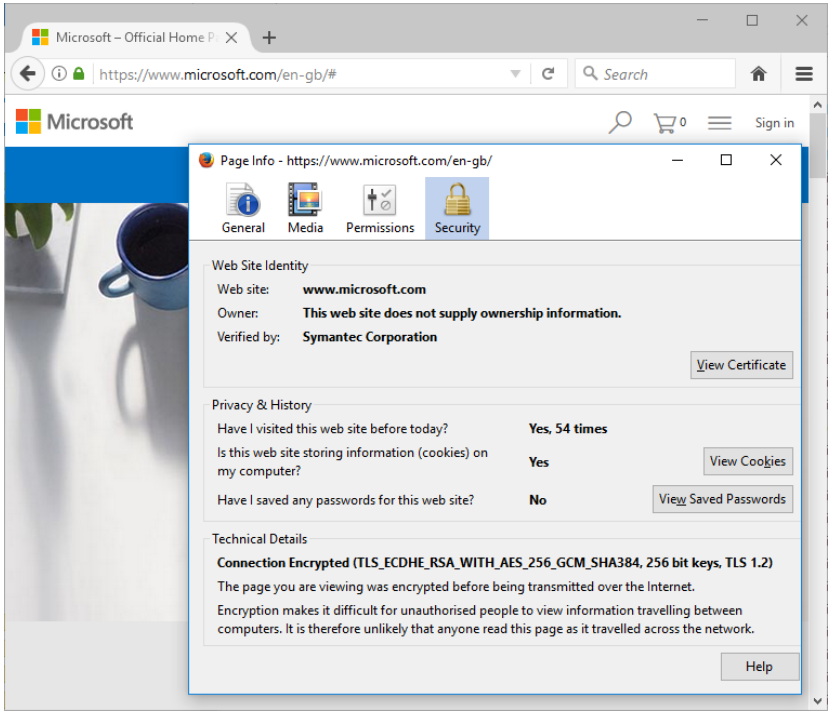


Screenshot used with permission from Microsoft.

Web Server Certificate Types

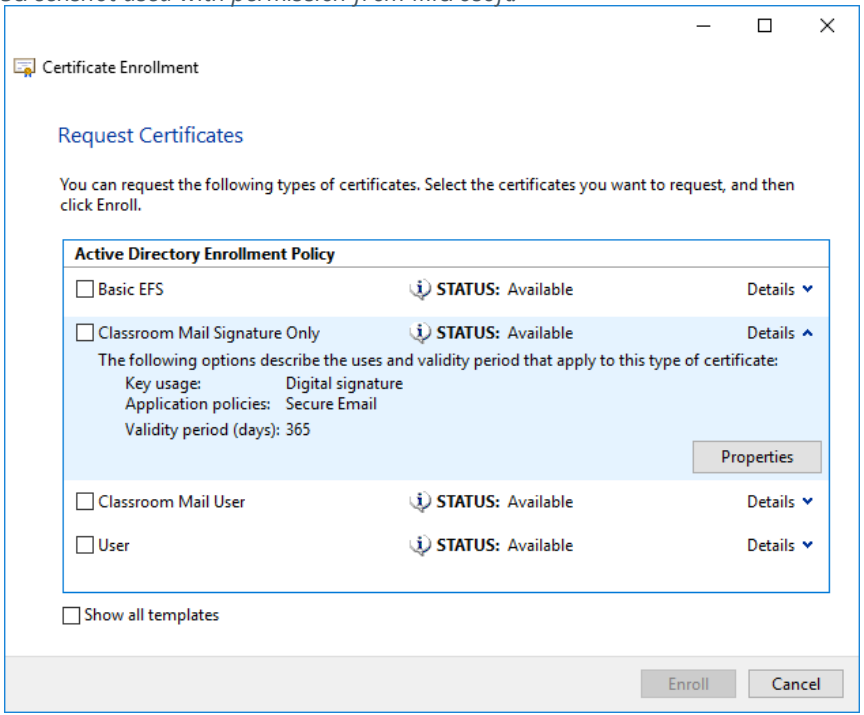
- Domain Validation (DV)
  - More rigorous identity checks
- Extended Validation (EV)
  - Even more rigorous identity checks

Screenshot used with permission from Microsoft.



Other Certificate Types

Screenshot used with permission from Microsoft.



- Machine/computer
  - Servers and network appliances
  - Identify by FQDN
- Email/user certificate
  - Can be various types (email, encryption, smart card logon, and so on)
  - Identify by email address
- Code signing
  - Validate publisher name
- Root certificate
  - Self-signed certificate for the CA
- Self-signed certificate
  - Must be manually trusted

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 6B

Implement PKI Management

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate and Key Management

- Key life cycle
  - Key generation
  - Certificate generation
  - Storage
  - Revocation
  - Expiration and renewal
- Vulnerabilities from improper management

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Key Recovery and Escrow

- M-of-N control for critical keys (root servers)
- Keys can be backed up to protect against data loss
  - Anyone with access to backup keys could impersonate the true key holder
  - Key recovery processes can be protected by M of N control
- Escrow backup
  - Placing archived keys with a trusted third party

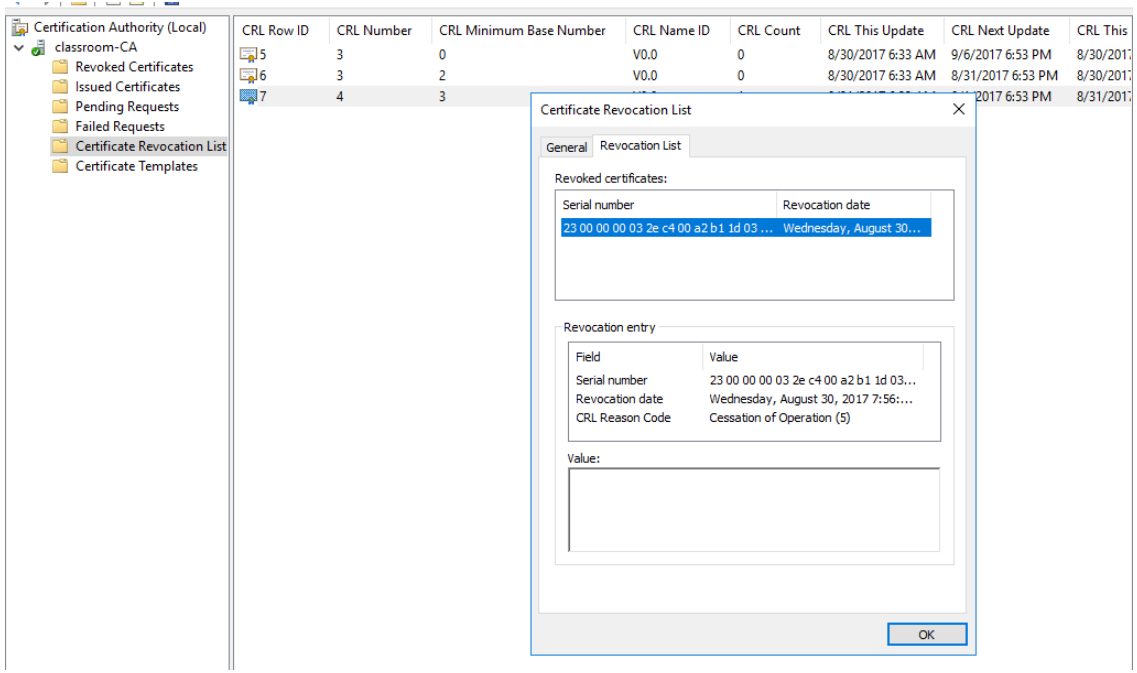
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate Expiration

- Certificate duration
- Certificate renewal
  - Use existing key pair
  - Re-key with newly generated key pair
- Expiration
  - Public key will no longer be accepted
  - Archiving versus destroying key material
  - Secure erasing methods

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate Revocation Lists



Screenshot used with permission from Microsoft.

- Revocation versus suspension
- Reason codes
- Certificate Revocation List (CRL)
  - List of revoked and suspended certificates
  - Browser CRL checking

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Online Certificate Status Protocol Responders

- Online Certificate Status Protocol (OCSP)
  - OCSP responder
  - Provide real-time status information (though some rely on CRLs)
  - Client queries single certificate per transaction
- OCSP stapling
  - Clients might need to make lots of certificate queries for a chain of trust
  - Queries can be used to track clients
  - Stapling proxies the OCSP response

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

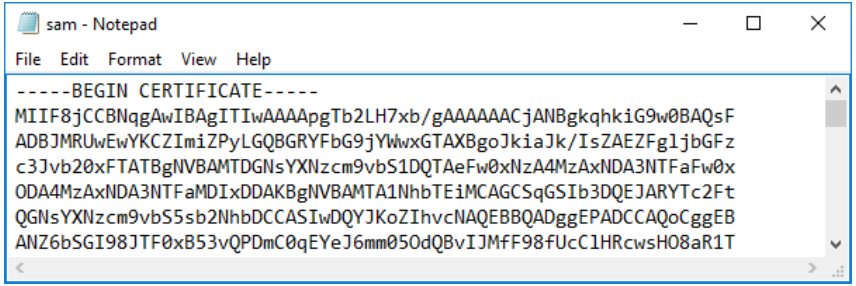
Certificate Pinning

- Defend against MitM attacks on chain of trust
- Web server references authorized public key(s) in HTTP header
  - HTTP Public Key Pinning (HPKP)
  - Certificate Transparency framework

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate Formats

- Distinguished Encoding Rules (DER)
  - Binary format
- Privacy-enhanced Electronic Mail (PEM)
  - Represent binary as ASCII using Base64 encoding
- .CER and .CRT file formats may be either binary or ASCII
- Personal information exchange
  - Export a private key (binary and password-protected)
  - .PFX or .P12 (PKCS #12)
- Export a certificate chain
  - .P7B (PKCS #7)



Screenshot used with permission from Microsoft.

OpenSSL

- Windows Certificate Services and `certutil`/PowerShell
- OpenSSL
  - Key pair generation and CA root certificate
  - Certificate requests
  - Viewing and verifying certificates
  - Converting certificate formats

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Certificate Issues

- Troubleshoot rejection of certificates by servers and clients
  - Existing certificate—check expiry and status
  - New certificate
    - Check key usage settings and requirements
    - Check subject name
    - Check chain of trust/root certificates
  - Verify time and date settings
- Audit certificate and PKI infrastructure

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.